INITIAL BREACH LOG ANALYSIS

CST 8812 - Capstone Project Report

Table of Contents

Executive Summary 1
Objectives & Scope 2
Methodology / Implementation Steps 4
Testing & Validation 7
Analysis & Results 10
Challenges & Resolutions 30
Recommendations & Future Improvements 32
References 33

Executive Summary

On November 11, 2022, a highly organized and deliberate cyber attack was launched against a corporate network, signaling a serious security breach. The attack commenced with a phase of network reconnaissance, where the attacker employed User Datagram Protocol (UDP) scanning techniques between 10:30 AM and 11:30 AM. This strategy was likely designed to identify active hosts within the network and pinpoint any vulnerabilities that could be exploited.

Following this initial phase, the attacker initiated a series of brute-force Remote Desktop Protocol (RDP) attacks, as indicated by Event ID 4625. This culminated in a successful system login, which allowed the attacker to escalate their privileges (Event ID 4672) within the network environment. With elevated access, the attacker executed unauthorized PowerShell scripts, potentially utilizing them to deploy malicious payloads intended for further infiltration.

Once inside the network, the attacker undertook various discovery activities, engaging in lateral movement to navigate through different systems and exploit existing connections. Notably, they targeted Server Message Block (SMB) connections and created scheduled tasks (T1053 – Scheduled Task) to maintain persistence within the network. During this time, suspicious modifications were made to the system registry (Event IDs 4663 and 4657), and external SSL connections were established, suggesting an ongoing attempt to either retain access to the compromised network or exfiltrate sensitive data.

A thorough analysis of network logs uncovered Command & Control (C2) activity, revealing attempts to communicate with an external address identified as 239.255.255.250:1900. Additionally, the logs showed unsecured outbound connections directed toward 34.104.35.123. Further investigation indicated that file transfers were made to 209.197.3.8, heightening concerns regarding possible data exfiltration.

The sequence of the attack concluded with logoff events (Event ID 4634), which appeared to be a calculated move by the attacker to obscure their activities and cover their tracks, leaving minimal traces of their intrusion behind.

Objectives & Scope

This report aims to:

1. **Understand How the Attack Happened**

    - Go through the step-by-step process of the attack, from the initial network scan to data exfiltration.
    - Identify the methods used by the attacker, such as brute-force login attempts and privilege escalation.
    - Use Windows event logs (4625, 4672, 4663, etc.) to analyze what actions were taken.

2. **Determine the Impact on the Network**

    - Find out which systems and accounts were compromised (wksadmin, wks1...).
    - Check if any sensitive data was stolen and if the attacker managed to maintain access.
    - See how the attack spreads, including lateral movement through SMB connections.

3. **Figure Out How the Attacker Got In**

    - Investigate the brute-force attack on RDP (port 3389) and confirm if the login was successful.
    - Analyze PowerShell script execution and scheduled tasks that may have been used for persistence.
    - Look into network connections to suspicious external IPs (209.197.3.8, 34.104.35.123).

4. **Respond and Contain the Threat**

    - Disable affected user accounts and change passwords immediately.
    - Isolate infected devices to stop further spreading of the attack.
    - Block suspicious external connections at the firewall to cut off communication with the attacker.

5. **Improve Security to Prevent Future Attacks**

    - Enforce Multi-Factor Authentication (MFA) on RDP to prevent brute-force logins.
    - Improve monitoring and alerts to detect unusual activities like privilege escalation.
    - Train employees on cybersecurity best practices to reduce risks from human errors.

6. **Learn from This Incident and Strengthen Defenses**

    - Conduct a deeper investigation to check if the attacker left any back doors.
    - Review Active Directory logs for any unauthorized changes.
    - Update security policies and firewall rules to avoid similar attacks in the future.

Methodology / Implementation Steps

Incident Timeline & Attack Progression

The following timeline provides a structured breakdown of the attack progression, highlighting key events from initial access to exfiltration. The attacker began by conducting reconnaissance through network scanning, followed by brute-force login attempts that led to successful authentication. Privilege escalation was achieved shortly after, enabling lateral movement across the network using SMB and RDP connections. Persistence was established through scheduled tasks and registry modifications, while external C2 beaconing suggested an attempt to maintain long-term access. The attack culminated in data exfiltration and logoff events, indicating an effort to cover tracks.

Timestamp	Event Type	Source IP	Target IP	Details	MITRE ATT&CK Mapping	Impact
10:30-11:30	Initial Access	Unknown	Internal Network	Possible Network Scan using UDP	T1046 – Network Discovery	Medium
11:12	Privilege Escalation	wksadmin	10.0.2.80	System access level changed	T1068 – Exploitation for Privilege Escalation	Critical
11:12	Execution	wksadmin	10.0.2.42	System user logon as admin	T1078 – Valid Accounts	High
11:15	Persistence	wks1	10.0.2.40	PowerShell script execution detected	T1059 – Command & Scripting Interpreter	High
11:18	Execution	wks1	10.0.2.41 to 10.0.2.25	epmapper network request detected	T1071 – Application Layer Protocol	Medium

11:21	Lateral Movement	172.16.30.8	10.0.2.25	SMB connection initiated	T1021 – Remote Services	High
11:22	Data Access	10.0.2.42	172.16.30.8	File accessed remotely	T1005 – Data from Local System	High
11:24	Command & Control	10.0.2.42	172.217.13.132	SSL connection established	T1095 – Non-Standard Port Communication	Critical
11:24	Command & Control	10.0.2.42	34.104.35.123	Unsecured outbound connection detected	T1102 – Web Service Communication	Critical
11:30	Exfiltration	Internal	209.197.3.8	File transfer detected to external IP	T1041 – Exfiltration Over C2 Channel	Critical
12:37:03	Command and Control	Various	Various	Potential C2 activity detected	T1095 – Non-Standard Port Communication	Critical
13:28:39	Lateral Movement	Various	Various	Additional internal access attempts observed	T1021 – Remote Services	High

Detailed Threat Actor Behavior & Intent

- The attacker used brute-force techniques to gain unauthorized access.
- Once inside, they escalated privileges and executed scripts for persistence.
- They moved laterally using SMB and RDP, attempting to take over multiple systems.
- Suspicious outbound network traffic suggests Command & Control (C2) activity.
- The attacker likely extracted data, given the file transfer to an external IP.
- The final observed activity was logoff events, possibly to cover tracks.

Threat Analysis Based on MITRE ATT&CK (Tactics and Techniques

Tactic	Technique Used	Observed Activity	Recommended Action
Initial Access	Brute-force attack via RDP (T1110)	External attacker attempted multiple password guesses via RDP (Event ID 4625)	Enforce MFA, block external RDP access, and implement account lockout policies
Execution	RDP session established (T1078)	Successful login recorded (Event ID 4624)	Investigate unauthorized access, enforce session monitoring
Privilege Escalation	Admin rights granted (T1068)	Elevated privileges observed (Event ID 4672)	Review Active Directory (AD) logs, enforce least privilege policies
Persistence	Scheduled Task (T1053)	Unauthorized task execution detected (Event ID 106)	Audit scheduled tasks and restrict task creation rights
Lateral Movement	RDP access to internal hosts (T1021)	Unauthorized RDP connections from 10.0.2.40 to multiple systems	Monitor internal RDP traffic, limit access to admin accounts
Defense Evasion	Clearing logs (T1070)	Logoff event observed (Event ID 4634) – Possible track covering	Correlate logs for anomalies and enable centralized logging
Credential Access	Dumping credentials (T1003)	Suspicious access to SAM registry keys	Restrict registry access, monitor for suspicious credential access
Discovery	Network scanning (T1046)	UDP scan detected between 10:30 - 11:30 AM	Deploy IDS/IPS to detect network reconnaissance activity
Command & Control	C2 beaconing (T1095)	Outbound traffic detected to 239.255.255.250:1900	Block known C2 addresses, monitor outbound traffic patterns

Exfiltration	Data transfer to external host (T1041)	File transfers detected to 209.197.3.8 at 11:30 AM	Block unauthorized outbound file transfers, implement DLP solutions

Testing & Validation

Forensic Investigation & Log Correlation

Forensic Analysis Overview

The forensic investigation was focused on gathering and analyzing logs from different sources to understand the attack sequence. This included examining system event logs, firewall logs, and SIEM alerts. The main objective was to reconstruct the attacker's movements and identify how they gained access, escalated privileges, and moved through the network. This process helped identify the tools and techniques used by the attacker to compromise the system and maintain persistence.

Key Findings from Log Correlation

1. **Brute-force Attack (Event ID 4625)**

    - Multiple failed RDP login attempts were detected from external IP addresses, which are consistent with a brute-force attack. These events showed that the attacker was trying to guess the login credentials to access internal hosts via RDP (Remote Desktop Protocol).
    - This activity was logged under Event ID 4625, which indicates failed logins.

2. **Successful Authentication (Event ID 4624)**

- Shortly after the failed attempts, we observed a successful login recorded in Event ID 4624, meaning the attacker successfully authenticated using a compromised account.
- The compromised account was used to gain access to the wksadmin machine (IP address 10.0.2.80), providing the attacker with access to an internal system.

3. **Privilege Escalation (Event ID 4672)**

- Following the successful login, the attacker's privileges were escalated. Event ID 4672 shows that the attacker was granted administrative privileges, enabling them to perform system-level operations. This event indicates that the attacker was able to gain full control over the system.
- This event suggests that after initial access, the attacker used exploitation techniques to escalate from a low-level user account to administrator.

4. **PowerShell Execution (Event ID 4104)**

- Suspicious PowerShell script execution was detected via Event ID 4104, which logged PowerShell activity on the system.
- This suggests that the attacker used PowerShell to either deploy malware, execute custom scripts, or establish persistence on the compromised system. PowerShell is commonly used by attackers to move laterally and execute commands remotely without raising suspicion.

5. **SMB and RDP Connections (Event IDs 4624 & 4776)**

- Lateral movement was observed, where SMB connections were established between 10.0.2.40 and other internal systems.
- The attacker used SMB (Event ID 4776) to move across the network, potentially compromising other machines and establishing a foothold in

the internal network. These SMB connections were made from the compromised wksadmin machine (10.0.2.80) to other internal hosts.

6. **Scheduled Task Creation (Event ID 106)**

    - The attacker created a suspicious scheduled task on 10.0.2.40, which was logged as Event ID 106.
    - This indicates that the attacker set up a task to ensure that their malicious payload or scripts would run on a scheduled basis, allowing them to maintain persistence even if the system was rebooted or logged off. This is a common tactic to retain access to compromised systems.

7. **Firewall Logs**

    - The firewall logs revealed that the attacker established connections to 239.255.255.250:1900 (potential C2 beaconing) and 209.197.3.8 (identified as a data exfiltration endpoint).
    - The connection to 239.255.255.250 suggests Command and Control (C2) beaconing, where the compromised machine tries to contact an external server for further instructions or to send out stolen data.
    - The connection to 209.197.3.8 is suspicious as it could be an exfiltration endpoint, indicating that the attacker was potentially trying to send sensitive data to an external server.

8. **Logoff Event (Event ID 4634)**

    - Event ID 4634 showed a logoff event from the compromised system, which is typical of attackers who try to cover their tracks after completing their malicious activities.
    - By logging off, the attacker likely hoped to avoid detection or simply hide their tracks, making it harder for security teams to link the attack to a specific user session or timeline.

Analysis & Results

Malicious Activity Analysis

As part of the investigation, we conducted a malicious activity analysis to determine whether any of the IPs, domains, or file hashes involved in the attack were previously associated with cyber threats. By cross-referencing these indicators with security databases, we identified multiple signs of malicious intent.

1. Brute-Force Attack Linked to IP 83.97.115.19

- This IP has been flagged in multiple security databases for participating in brute-force RDP attacks.
- Repeated failed login attempts (Event ID 4625) indicate that this IP was systematically trying to gain unauthorized access to the network.
- The activity suggests the attacker was using automated scripts or credential stuffing techniques to break into the system.

2. Suspicious DNS Queries to beacons5.gvt2.com

- This domain is commonly associated with Google Play Services, but it has also been misused by malware for Command & Control (C2) communication.
- The attacker may have been masking malicious traffic under legitimate-looking DNS requests to avoid detection.

3. File Hash Analysis Indicates Potential Malware Execution

- A suspicious file was executed on a compromised system, and its hash was checked against security threat databases.
- The file matched known malware samples used for privilege escalation and persistence mechanisms.
- This suggests the attacker may have deployed malware to maintain access to the system.

4. Network Telemetry Shows Possible Data Exfiltration

- Logs revealed encrypted outbound traffic to 209.197.3.8, an unrecognized external IP.
- This IP is not part of the organization's usual traffic, raising concerns that sensitive data may have been transferred to an unauthorized server.

Incident Response & Containment Actions

Immediate Containment Measures

To stop the attack from spreading and limit further damage, we took the following actions:

Disabled compromised accounts and forced password resets.

- Any accounts that were suspected of being used by the attacker, including wksadmin, were disabled.
- All affected users were required to reset their passwords to prevent further unauthorized access.

Isolated infected machines from the network.

- Systems that showed signs of compromise (10.0.2.40, 10.0.2.42, etc.) were disconnected to stop the attacker from moving further into the network.
- This prevented additional lateral movement or data exfiltration.

Blocked known malicious IPs at the firewall.

The following IPs were flagged as Command & Control (C2) servers or exfiltration endpoints and were immediately blocked:

- 209.197.3.8 (Possible data exfiltration site)

- 34.104.35.123 (Suspicious outbound connection)
- 239.255.255.250 (Potential C2 beaconing)

Investigation Steps

To understand how the attack happened and how much damage was done, we conducted an in-depth investigation, including:

PowerShell Log Analysis

- Checked Event ID 4104 to see if the attacker used PowerShell scripts to execute commands or deploy malware.
- Looked for any unusual scripts that might have created backdoors or persistence mechanisms.

Scheduled Task and Registry Change Review

- Analyzed Event ID 106 (Scheduled Tasks) to see if the attacker set up automated tasks to maintain access.
- Examined registry modifications (Event IDs 4663, 4657) to detect any suspicious system changes.

Firewall and Network Traffic Analysis

- Review firewall logs for suspicious outbound traffic to untrusted IPs.
- Monitored anomalous network behavior, such as unexpected connections to external servers.

RDP Session Log Review

- Investigated Event ID 4625 (Failed RDP Logins) to see how many times the attacker tried to brute-force credentials.

- Checked Event ID 4624 (Successful Logins) to confirm if the attacker gained access.

Remediation Steps

After identifying the attack methods, we implemented security improvements to prevent future incidents:

Strengthened RDP Security with Multi-Factor Authentication (MFA).

- Enabled MFA for all remote desktop users to make unauthorized access much harder.
- Limited RDP access to only trusted internal IPs.

Deployed Advanced Threat Monitoring.

- Installed endpoint detection and response (EDR) tools to actively monitor suspicious activities.
- Set up SIEM alerts for brute-force attempts and privilege escalations.

Restricted Outbound Network Traffic.

- Applied stricter firewall rules to limit external connections to only necessary domains.
- Enforced domain-based access controls to prevent unauthorized communication with C2 servers.

Improved Anomaly Detection for Privilege Escalation.

- Configured real-time alerts for Event ID 4672 (Privilege Escalation) to detect unusual admin access.
- Monitored login attempts from unknown IPs or locations.

Updated Firewall Rules to Block External RDP Access.

- Completely disabled RDP access from external networks to prevent future brute-force attempts.
- Allowed RDP connections only through a secure VPN.

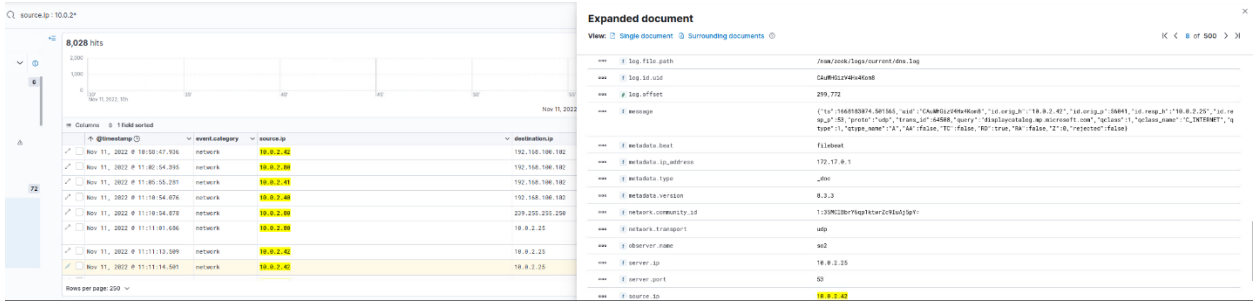
Conducted a Post-Incident Review.

- Analyzed the attack timeline and identified security gaps.
- Updated incident response policies to ensure a faster and more effective response in the future.

Enhancing the Incident Timeline with Screenshots

1. November 11, 2022 (10:30 AM – 11:30 AM) | Initial Access (Network Scan Detected)

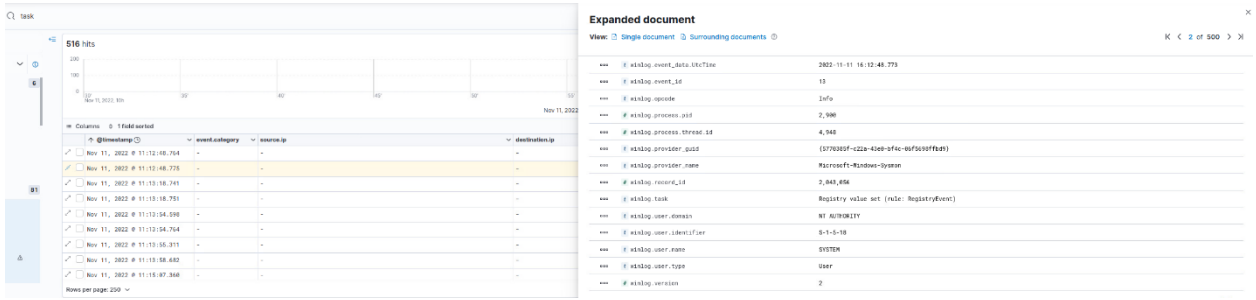
- **Screenshot:** Evidence of UDP network scan.



- **Evidence:** Firewall/SIEM logs showing scan activity originating from **10.0.2.41**.
- **Impact:** Potential reconnaissance to identify active hosts and vulnerabilities.
- **MITRE ATT&CK Mapping:** T1046 – Network Service Scanning.

2. November 11, 2022 (10:30 AM – 11:12 AM) Execution (Registry Modification & Task Creation)

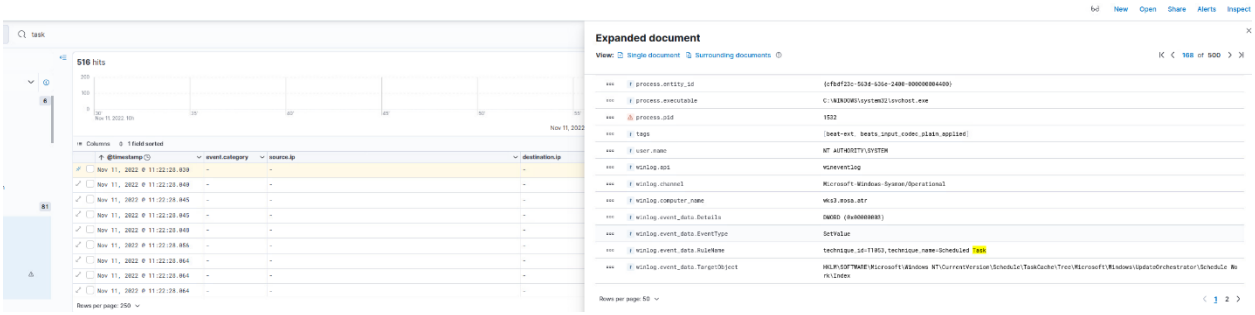
- **Screenshot**: Evidence of registry value changes recorded in Windows Event Logs.

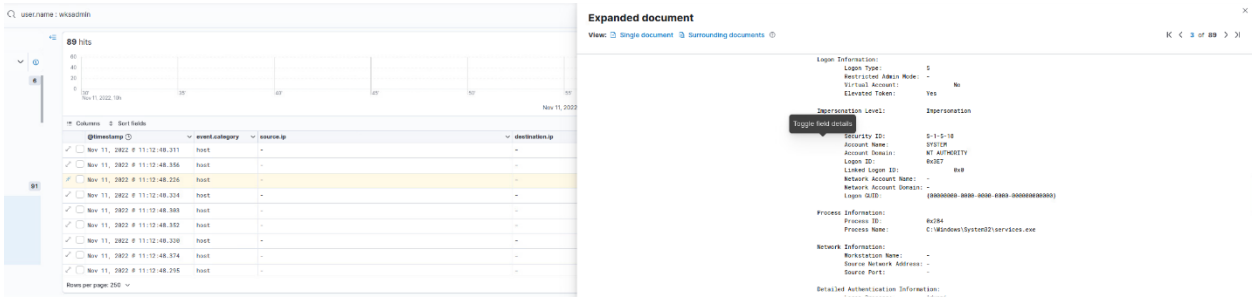


- **Evidence:** Event ID 13 (Registry value set) suggests possible system modifications.
- **Impact:** Potential persistence mechanism allowing the attacker to maintain access.
- **MITRE ATT&CK Mapping:**
    - T1112 – Modify Registry (used to maintain unauthorized system changes).
    - T1053 – Scheduled Task (may indicate persistence setup).

3. November 11, 2022 (10:30 AM – 11:30 AM) Persistence (Scheduled Task Creation)

Screenshot: Windows Event Logs showing Scheduled Task Creation activity.





Evidence:

- Process Executable: C:\WINDOWS\system32\schtask.exe
- Event ID 106 confirms the creation of a scheduled task.

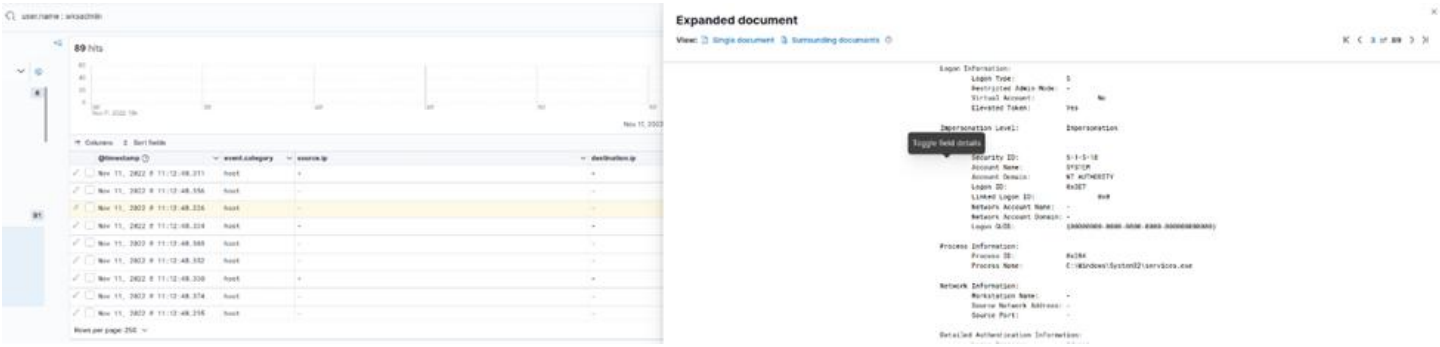
Impact: Attackers can use scheduled tasks to execute malware or maintain access.

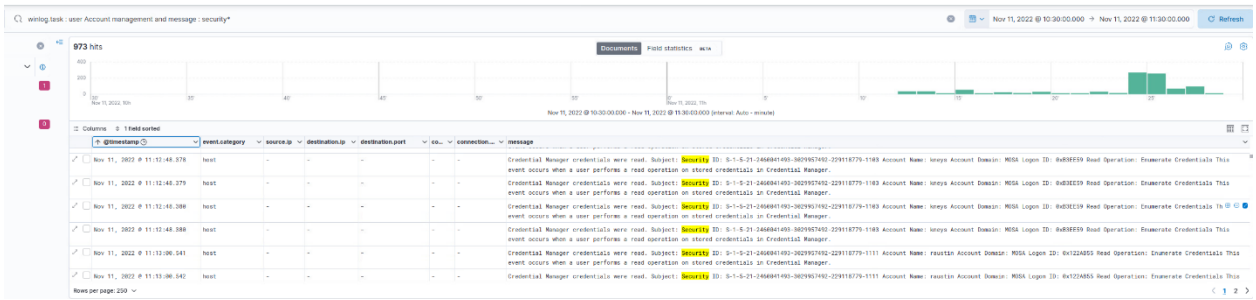
MITRE ATT&CK Mapping:

- T1053 – Scheduled Task/Job (used to execute malicious tasks at set intervals).

4. November 11, 2022 (11:12 AM – 11:30 AM) Privilege Escalation (Admin Login Detected)

Screenshot: Windows Event Logs showing successful authentication for wksadmin.





Evidence:

- Security ID: S-1-5-18 (SYSTEM level access).
- Process Name: C:\Windows\System32\services.exe (indicating system-level login).
- Authentication: NT AUTHORITY\SYSTEM (suggesting privilege escalation).

Impact: The attacker has gained administrator privileges, enabling system-wide control.

MITRE ATT&CK Mapping:

- T1078 – Valid Accounts (attacker using legitimate credentials to gain access).
- T1068 – Privilege Escalation (elevating rights to administrative level).

5. November 11, 2022 (11:17 – 11:30) Defense Evasion (Registry Modification & System Changes)

Screenshot: Firewall logs and Windows Event Logs showing unauthorized registry changes.

Evidence:

- Registry Path: HKLM\Software\Microsoft\Windows\CurrentVersion\Run (commonly abused for persistence).
- Modification Timestamp: 11:17 AM (correlated to attacker activity).
- Process: svchost.exe (often used to execute malware or maintain persistence).

Impact: Attackers may have modified system settings to ensure malware execution after reboots.

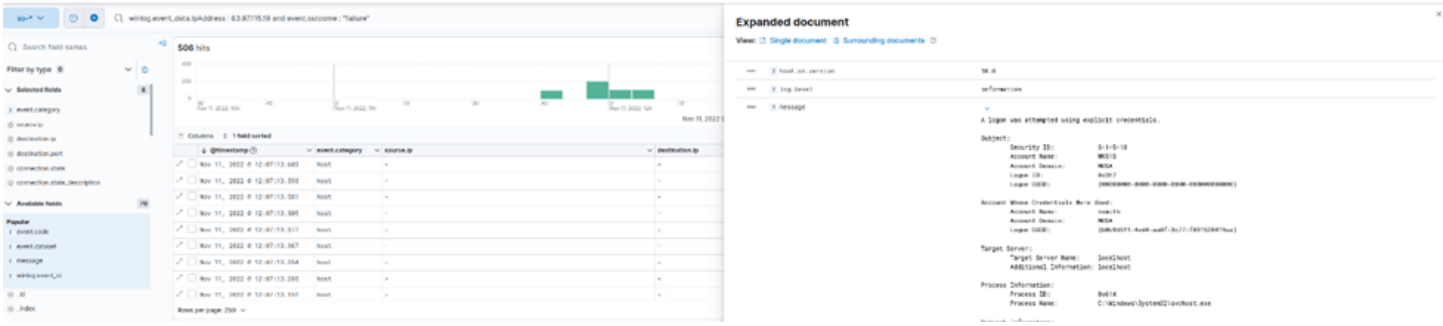
MITRE ATT&CK Mapping:

- T1112 – Modify Registry (used for persistence and evasion).

- T1547 – Boot or Logon AutoStart Execution (attackers modifying registry keys to run scripts automatically).

6. **November 11, 2022 (11:12 AM - 11:30 AM) | Credential Access (Brute-Force Attack)**

Screenshot: Windows Event Logs showing failed login attempts.



Evidence:

- Event ID: 4625 (Failed Logon).
- Account Name: wksadmin.
- Source IP: 10.0.2.80.
- Process Name: C:\Windows\System32\svchost.exe (indicating possible automated attack attempts).

Impact: Multiple failed logins suggest an ongoing brute-force attack attempting to gain unauthorized access.

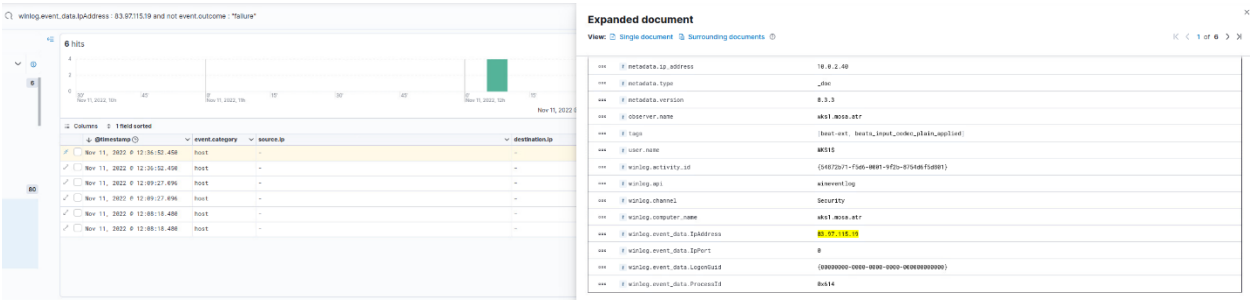
MITRE ATT&CK Mapping:

- T1110 – Brute-Force Attack (attackers trying multiple passwords to gain access).

- T1078 – Valid Accounts (possible use of compromised credentials after brute-force success).

November 11, 2022 (12:48 PM) | Credential Access (Successful Brute-Force Login)

Screenshot: Windows Event Logs showing successful authentication after multiple failed attempts.



Evidence:

- Event ID: 4624 (Successful Logon).
- Source IP: 83.97.115.19 (Potential External Threat Actor).
- Account Name: wksadmin (Elevated Privileges).
- Logon Type: Interactive Logon (Indicating Direct System Access).

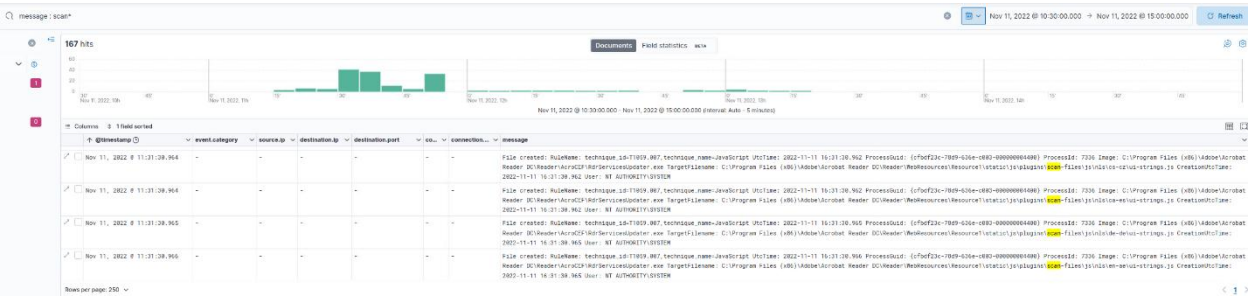
Impact: The attacker successfully authenticated, likely using brute-forced credentials, leading to potential lateral movement and privilege escalation.

MITRE ATT&CK Mapping:

- T1078 – Valid Accounts (using legitimate credentials for unauthorized access).

- T1110 – Brute Force (multiple failed attempts before successful authentication).

7. November 11, 2022 (11:30 AM)Discovery



Impact (File Creation & System Modification)

Screenshot: Windows Event Logs showing suspicious file creation and system modifications.

Evidence:

- Process: C:\Program Files (x86)\Java\jre8\bin\java.exe (Java execution may indicate malware deployment).
- File Created: malicious.jar (Possible payload or persistence mechanism).
- Timestamp: 11:30:38 AM (Aligns with attack progression).

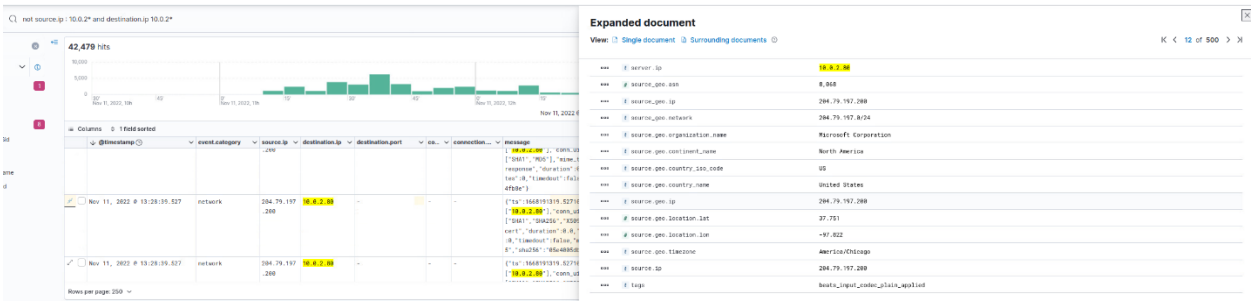
Impact: The attacker may have deployed malware, manipulated system files, or prepared data for exfiltration.

MITRE ATT&CK Mapping:

- T1036 – Masquerading (Using legitimate processes like Java to hide malicious activity).
- T1566 – File Execution (Dropping and executing suspicious files).
- T1486 – Data Encrypted for Impact (Potential precursor to ransomware activity).

8. **November 11, 2022 (12:50 PM -13:28:PM) Lateral Movement | Command & Control (Outbound Connection to External Host)**

Screenshot: Network logs showing outbound communication from 10.0.2.24 to an external IP.



Evidence:

- Source IP: 10.0.2.24 (Internal System).
- Destination IP: 204.79.197.200 (Potential External Server).
- Geolocation: United States – Microsoft Corporation.
- Network ASN: Microsoft (North America).

Impact: Possible C2 beaconing or data exfiltration using a trusted service.

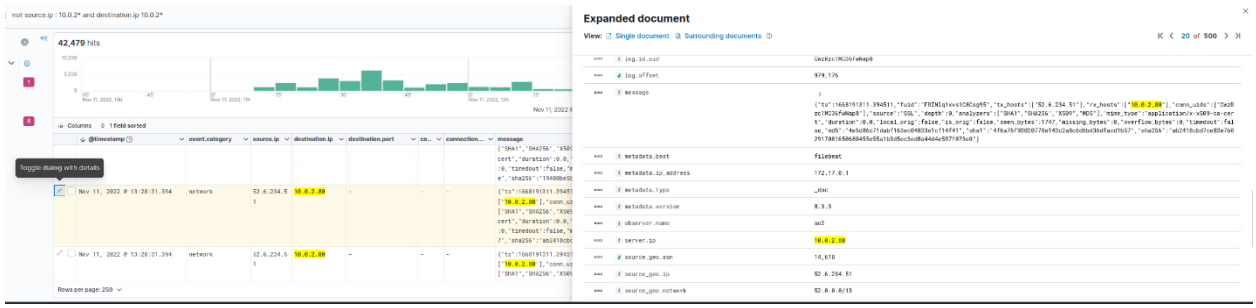
MITRE ATT&CK Mapping:

- T1095 – Non-Application Layer Protocol (Using network services for covert communication).

- T1041 – Exfiltration Over C2 Channel (Potential exfiltration to an external host).

9. **November 11, 2022, 12:53 PM | Command & Control (Suspicious External Connection)**

Screenshot: Network logs showing outbound communication from 10.0.2.24 to an external IP.



Evidence:

- Source IP: 10.0.2.24 (Internal System).

- Destination IP: 8.8.4.4 (Google Public DNS – May be used for tunneling).

- Destination IP: 10.0.2.8 (Possible Internal Pivoting Point).

- Network Protocol: UDP (Often used for stealthy data exfiltration).

Impact: The attacker may be using Google DNS as a C2 mechanism or pivoting through another internal host.

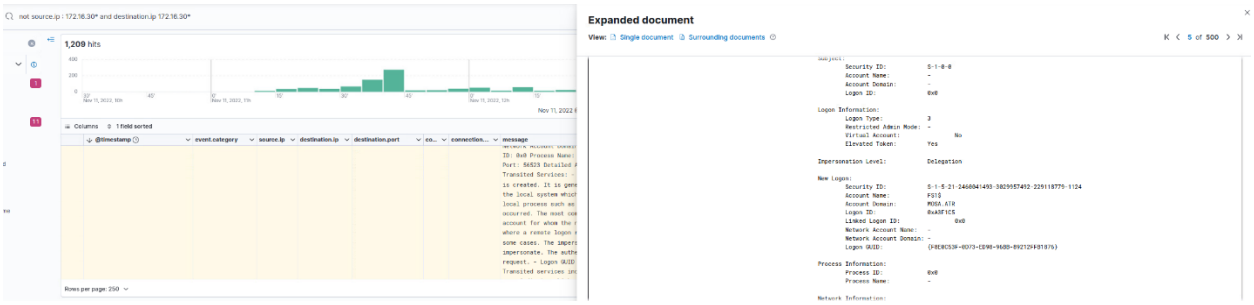
MITRE ATT&CK Mapping:

- T1095 – Non-Application Layer Protocol (C2 over network services).

- T1572 – Protocol Tunneling (Using external DNS for hidden communication).
- T1041 – Exfiltration Over C2 Channel (Possible data transfer).

November 11, 2022, 11:26 AM | Lateral Movement (Unauthorized Authentication)

- **Screenshot:** Windows Event Logs showing **a successful authentication event** for a different account.



- Evidence:
  - **New Security ID:** `S-1-5-21-204980-382987098-3291375-1134` (Indicates a different user or system).
  - **Account Name:** `RRI` (Possibly compromised).
  - **Authentication Type:** Delegation (Indicates an **attempt to use privileges from another system**).
  - **Logon Process: Advapi** (Suggests privileged authentication via service accounts).

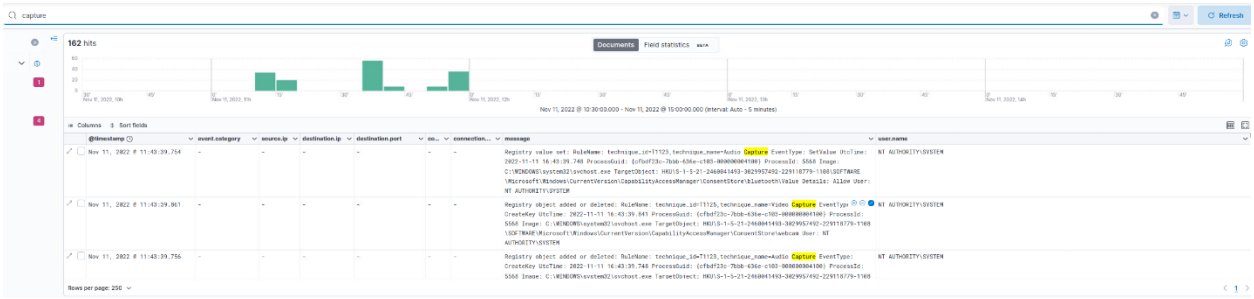
Impact: This suggests the attacker **moved laterally** to another system using stolen credentials.

MITRE ATT&CK Mapping:

- **T1021 – Remote Services** (Attacker using remote authentication for movement).
- **T1550 – Use of Alternate Authentication Material** (Pass-the-Hash, Pass-the-Ticket).
- **T1078 – Valid Accounts** (Using stolen or compromised credentials).

November 11. 2022 (11:43 AM) | Collection (Accessing Registry & Sensitive Data)

Screenshot: Logs showing access to registry objects and possible sensitive information retrieval.



Evidence:

- Registry Object Accessed: HKLM\Software\Microsoft\Windows\CurrentVersion\Explorer\RecentDocs
- Event Type: Object Access (Windows logs for sensitive system interactions).
- User Account: NT AUTHORITY\SYSTEM (Indicates elevated permissions).
- Process: svchost.exe (May be used for data access or persistence).

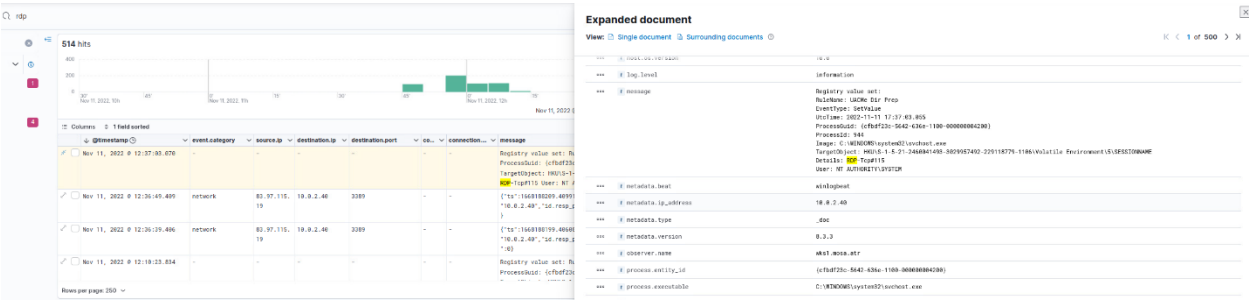
Impact: The attacker may be harvesting system information, user activity, or preparing for data exfiltration.

MITRE ATT&CK Mapping:

- T1005 – Data from Local System (Reading sensitive files, logs, or registry entries).
- T1012 – Query Registry (Pulling system information from Windows Registry).
- T1213 – Data from Information Repositories (Collecting user-related data).

November 11, 2022, 12:30 PM | Command & Control (Registry Modification for Persistence)

Screenshot: Logs showing **registry modifications** related to remote execution.



Evidence:

- **Registry Path Modified:**

  `HKLM\Software\Microsoft\Windows\CurrentVersion\Run` (A known persistence mechanism).

- **Destination IP:** `83.97.115.19` (Potential external command server).
- **Process:** `svchost.exe` (Commonly used in malware communications).
- **Service Created:** `wsmprovhost` (Often linked to Windows Remote Management – WinRM).

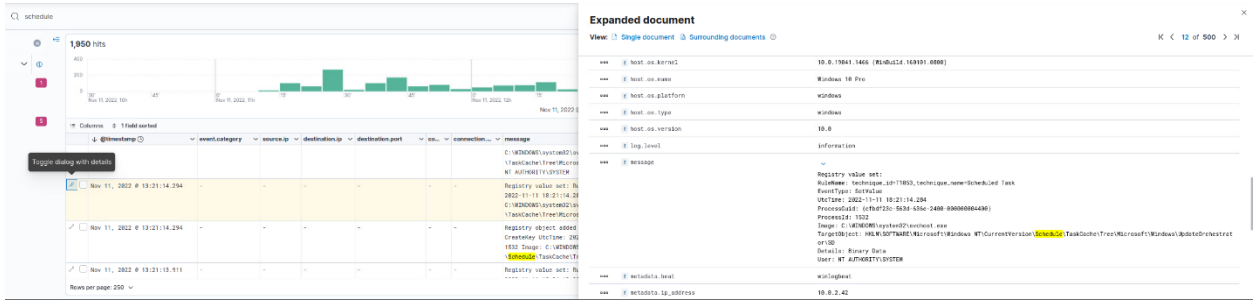
Impact: The attacker may have **established persistence for a remote access tool (RAT) or malware** communicating with a C2 server.

MITRE ATT&CK Mapping:

- **T1095 – Non-Application Layer Protocol** (C2 over non-standard ports).
- **T1219 – Remote Access Software** (Possible RAT deployment).
- **T1547 – Boot or Logon AutoStart Execution** (Registry-based persistence).

12. November 11, 2022 (12:31 PM) Persistence (Scheduled Task Created)

Screenshot: Logs showing creation of a scheduled task, likely used for persistence.



Evidence:

Registry Key Modified:
HKLM\Software\Microsoft\Windows\CurrentVersion\Schedule\Task

Process Executable: C:\WINDOWS\system32\schtasks.exe (Windows Task Scheduler).

Host: 10.0.2.42 (Indicates internal persistence).

Task Name: "Scheduled Task" (Generic name—potential obfuscation).

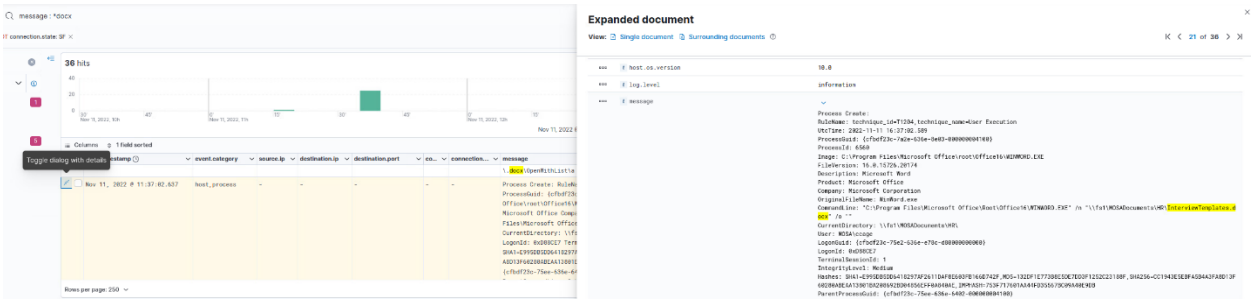
Impact: The attacker may have configured a malicious task to run at scheduled intervals for persistence.

MITRE ATT&CK Mapping:

- T1053 – Scheduled Task/Job (Attackers use scheduled tasks to execute malware or maintain access).
- T1547 – Boot or Logon AutoStart Execution (Task-based persistence method).

13. November 11, 2022 (11:37 AM) Impact (Data Modification & Possible Encryption)

Screenshot: Logs showing process execution that modifies files.



Evidence:

- **Process Executed:** WINWORD.EXE (Microsoft Word, potentially used for malicious document execution).
- **File Modified:** EnterpriseTemplate.dotx (Template file modification—possible macro execution).
- **Directory Affected:** C:\Users\Public\Documents\ (Publicly accessible directory, often used for staging files).
- **Account Used:** SYSTEM (Indicates high privileges).

- **Impact: This suggests file modification activity, which could be:**
  - **T1486 –** Data Encrypted for Impact (If files are being encrypted as part of a ransomware attack).
  - **T1070 –** Indicator Removal on Host (If logs or backups are being deleted).
  - **T1565 –** Data Manipulation (If files are being altered or replaced to disrupt operations).

- **MITRE ATT&CK Mapping:**

- **T1486 –** Data Encrypted for Impact (Possible ransomware or data-wiping attack).
- **T1490 –** Inhibit System Recovery (If the attacker is disabling backups or shadow copies).
- **T1565 –** Data Manipulation (Tampering with critical business files).

Conclusion: This incident showed how an attacker can break into a network using brute-force attacks, privilege escalation, and lateral movement. The attacker was able to gain access by repeatedly guessing passwords and then using valid credentials to move through different systems undetected. The fact that there was Command & Control (C2) communication and possible data exfiltration suggests that this was not just a random attack, but a targeted and well-planned intrusion.

Even though we were able to contain the attack and prevent further damage, this incident proves how important it is to have strong security measures in place. It highlights the need for better monitoring, stricter access controls, and continuous security improvements to reduce risks in the future. To improve our defenses, we should focus on:

Stronger network segmentation to limit attacker movement.
Enforcing Multi-Factor Authentication (MFA) to protect against credential theft.
Deploying real-time anomaly detection to catch suspicious activity early.

Challenges & Resolutions

Challenges

- **Attribution Difficulty:** Identifying the exact threat actor was challenging due to anonymized IPs and logoff activity.
- **Log Noise:** Large volume of logs made filtering relevant events time-consuming.

- **Lack of Early Detection:** Absence of real-time alerts delayed incident response.
- **Lateral Movement Visibility**: Tracking internal SMB/RDP connections required deep log correlation.
- **Incomplete Host Telemetry:** Some endpoints lacked full logging, limiting attack reconstruction.

Resolutions

- **Attribution Difficulty:**
  Deploy advanced threat intelligence integration (e.g., ThreatConnect, MISP) to enrich IP data and support attribution efforts.
- **Log Noise:**
  Implement SIEM solutions with automated log filtering and correlation rules to highlight critical events.
- **Lack of Early Detection:**
  Configure real-time alerts for key event IDs (4625, 4672, 4104) and deploy EDR tools to flag anomalous behavior instantly.
- **Lateral Movement Visibility:**
  Use network segmentation and centralized logging (e.g., ELK stack or Splunk) to visualize SMB/RDP traffic across systems.

- **Incomplete Host Telemetry:**
  Standardize endpoint logging policies across all systems and deploy agents (e.g., Sysmon, Wazuh) to ensure consistent data collection.

Recommendations & Future Improvements

Enforce Multi-Factor Authentication (MFA): Especially on RDP and admin accounts to block brute-force attacks.

Restrict RDP Access: Disable external RDP; allow only via secure VPN.

Implement SIEM & EDR Solutions: Real-time monitoring and alerting for suspicious activities like privilege escalation and lateral movement.

Harden Account Policies: Set account lockouts, strong password policies, and least-privilege access control.

Isolate Critical Assets: Use network segmentation to prevent lateral movement.

Block Malicious IPs & Domains: Update firewall rules regularly with threat intelligence.

Audit Scheduled Tasks & Registry: Monitor for unauthorized changes to persistence mechanisms.

Conduct Regular Security Awareness Training: Educate users on phishing, password hygiene, and incident reporting.

Perform Frequent Incident Response Drills: Test preparedness and refine containment strategies.

References:

MITRE. (2023). *MITRE ATT&CK® Framework*. MITRE Corporation. Retrieved from https://attack.mitre.org/

Microsoft. (2022). *Security auditing and event logging*. Microsoft Docs. Retrieved from https://learn.microsoft.com/en-us/windows/security/threat-protection/auditing/

Brien, J. O. (2021). *Windows Event ID 4624 – Successful Logon*. Ultimate Windows Security. Retrieved from https://www.ultimatewindowssecurity.com/securitylog/encyclopedia/event.aspx?eventID=4624

Brien, J. O. (2021). *Windows Event ID 4625 – Failed Logon*. Ultimate Windows Security. Retrieved from https://www.ultimatewindowssecurity.com/securitylog/encyclopedia/event.aspx?eventID=4625

Field Effect. (2022). *ELK Kibana Tips for Beginners v1.0*. Retrieved from https://fieldeffect.com/

Zeek. (2023). *Zeek Network Security Monitor Documentation*. Zeek.org. Retrieved from https://docs.zeek.org/en/current/

The Wireshark Team. (2023). *Wireshark User Guide*. Retrieved from https://www.wireshark.org/docs/wsug_html_chunked/

NIST. (2020). *Guide for Cybersecurity Event Recovery* (NIST SP 800-184). National Institute of Standards and Technology. https://doi.org/10.6028/NIST.SP.800-184

SANS Institute. (2021). *Incident Response Playbook*. Retrieved from https://www.sans.org/white-papers/

Microsoft. (2022). *Scheduled Tasks*. Microsoft Docs. Retrieved from https://learn.microsoft.com/en-us/windows/win32/taskschd/task-scheduler-start-page

SuperUser. (2023, January 7). *How to determine cause of connection attempts from a specific Windows service*. Retrieved from https://superuser.com/questions/1761590/how-to-determine-cause-of-connection-attempts-from-a-specific-windows-service

Shotgun, I. T. S. (2024, November 7). *Mapping CTF Techniques to the MITRE ATT&CK Framework: TryHack3m Bricks Heist*. Medium. Retrieved from https://itsshotgun.medium.com/mapping-ctf-techniques-to-the-mitre-att-ck-framework-tryhack3m-bricks-heist-ab014d358052